

CTI4RA: Cyber Threat Intelligence for Risk Assessment

Vita Santa Barletta
Department of Computer Science
University of Bari Aldo Moro
Bari (BA), Italy
vita.barletta@uniba.it

Nicola Balzano
Department of Computer Science
University of Bari Aldo Moro
Bari (BA), Italy
n.balzano2@alumni.uniba.it

Lorenzo Colelli
Department of Computer Science
University of Bari Aldo Moro
Bari (BA), Italy
l.colelli2@alumni.uniba.it

Alessandro Pagano
Department of Computer Science
University of Bari Aldo Moro
Bari (BA), Italy
alessandro.pagano@uniba.it

Antonio Piccinno
Department of Computer Science
University of Bari Aldo Moro
Bari (BA), Italy
antonio.piccinno@uniba.it

Qaisar Sohail
Department of Computer Science
University of Bari Aldo Moro
Bari (BA), Italy
qaisar.sohail@uniba.it

Abstract—Organizations, which are the foundation of today's society and economics, are growing an ever wider knowledge about Cyber Threat Intelligence (CTI), risk assessment, and management, in an ever more connected environment. In this context, cybersecurity is essential to ensure the safety of any Asset. These valuable entities are subject to being compromised by Threat Actors and thereafter lead to a possible wide range of consequences. An attacker could exploit a given vulnerability to its advantage and leverage it to gather, forge, and disclose sensitive information. Therefore, it has been found to be a must to detect Common Vulnerabilities and Exposures (CVE) and Common Weakness Enumeration (CWE) to protect valuable Assets. Once a vulnerability has been identified, such information could be used to assess other related vulnerabilities that might have happened throughout the Cyber Kill Chain. This paper presents methods and procedures to study known attack patterns, those that might be encountered starting from initial attack patterns and calculate the probability of being attacked by known intrusion sets based on the patterns found. The goal is to obtain a risk assessment of the organization through an approach that allows the retrieval and consultation of mitigation techniques and all information of the CTI and the relationships between them. It can be affirmed that the resulting system supports analysts in the assessment of risk exposure, as well as providing ways to comprehend the effort needed to secure vulnerabilities and their returning benefits.

Keywords—Cybersecurity, CTI, vulnerability, APT, assessment

I. INTRODUCTION

Cyber Threat Intelligence (CTI) plays a crucial role in dynamic risk assessment and management frameworks. Sharing CTI can enhance defense against sophisticated cyber-attacks, but it also carries risks that need evaluation [1]. To address this, ontology-based semantic knowledge modeling has emerged as a promising solution for cyber risk monitoring, aligning with STIX concepts [2]. An integrated architecture using OWL, semantic reasoners, and SWRL can enable near real-time risk assessment at operational, tactical, and strategic levels [3].

To implement effective risk management, organizations can benefit from a capability maturity model for risk assessment that incorporates threat intelligence using a risk register. This model provides a clear path for organizations to conduct risk assessments by the latest threats [4]. Therefore, keeping in mind that each of these approaches collectively contribute to more robust and dynamic cyber risk management strategies, the paper analyzes how CTI information can be leveraged to develop specific and worthwhile features. The following are the main contributions:

- 1) Integrating the MITRE ATT&CK [5], [6] and MITRE ATLAS [7] matrices into a unified matrix to facilitate comprehensive threat analysis;
- 2) Identifying preventive measures for attack patterns that have been encountered, enhancing proactive defense mechanisms;
- 3) Analyzing potential intrusion sets responsible for an attack based on the attack patterns that have been detected;

CTI4RA (Cyber Threat Intelligence for Risk Assessment) aims to inspire researchers and analysts to continue processing CTI information, fostering the creation of additional valuable methods and tools for enhancing cybersecurity measures [8].

The paper is organized as follows: Section II describes the approach identified to develop Cyber Threat Intelligence for risk assessment; Section III shows the relationships between the vulnerability and associated attack patterns; Section IV explains how to calculate the risk score; Section V sets out the conclusions.

II. CTI4RA: CYBER THREAT INTELLIGENCE

A. Unified matrix ATT&CK and ATLAS

Reconstructing the Cyber Kill Chain [9] (CKC) (Figure 1) is essential for creating a unified matrix that combines the individual ATT&CK and ATLAS matrices [10], [11]. By doing

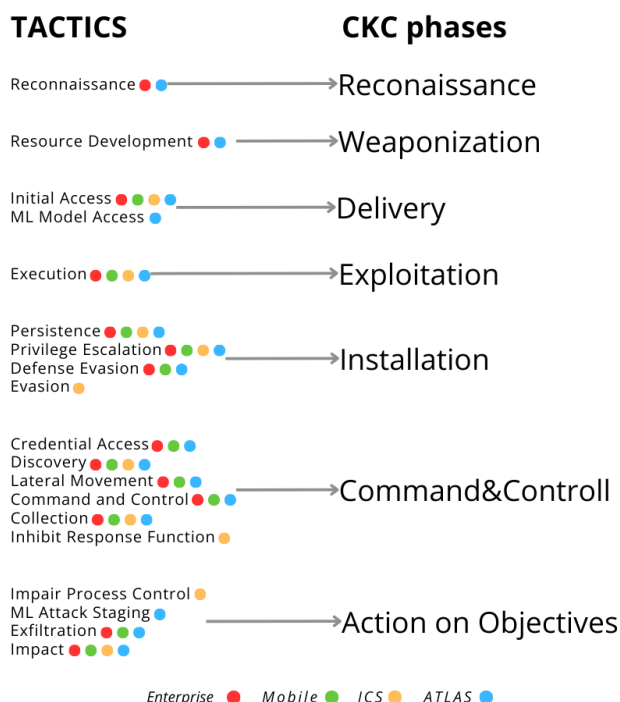


Fig. 1. Cyber Kill Chain reconstruction from ATT&CK and ATLAS tactics.

so, was feasible to integrate a comprehensive interface that displays all known attack patterns in a single view, organized by the phases of the CKC. This unified matrix consolidates disparate data sources into a single, cohesive framework, ensuring that all relevant attack patterns, tactics, techniques, and procedures (TTPs) are accounted for [12], [13].

To implement this feature, has been reconstruct the CKC using the tactics in the ATT&CK and ATLAS matrices, based on the descriptions of those tactics and their execution sequence (Figure 1). This reconstruction guarantees an accurate integration that reflects real-world attack scenarios.

The integration of a unified matrix streamlines the analysis process, making threat assessments more comprehensive. By leveraging this matrix, organizations can effectively track the progression of potential threats through various stages of the CKC, from Reconnaissance to Action on Objectives. This approach enhances the ability to monitor and mitigate threats efficiently. Moreover, the unified matrix allows cybersecurity experts to understand and anticipate the next steps in an attack sequence. It aids in identifying the relationships between different attack patterns and understanding how threats evolve over time. This holistic view is crucial for improving the overall security posture of an organization and ensuring timely and effective responses to cyber threats.

B. Attack Patterns Prevention based on relationships

By leveraging the MITRE ATT&CK (by its python lib [14]) and MITRE ATLAS (whose library to obtain this info has been reconstructed, because currently there is no) frameworks, one can access comprehensive information on attack patterns,

software, campaigns, and other related data, as well as the intricate relationships between these elements.

Thanks to this information, it is possible to identify the attack patterns related to a specific campaign or software. Starting from an initial attack pattern encountered, it is achievable to regard as possibly detectable the other techniques used by the software or the campaigns in relationship to the detected pattern. This may be helpful to reconstruct the software used during an attack, or whether the attacker is replicating a known campaign. This methodology is useful to give priority to the verification of attack techniques that may have occurred to mitigate them with greater speed.

By considering the CKC phases associated with an attack pattern, was possible to determine which attack patterns might have preceded the identified pattern (Figure 3) and which ones could potentially follow it (Figure 4). This functionality allows cybersecurity experts to understand which patterns to investigate following an initial detection.

It also enables consideration of all potential software or campaigns reported in the MITRE frameworks, ensuring that the information is always current and comprehensive. This approach enhances the ability to anticipate and respond to evolving threats effectively.

C. Analyzing Potential Intrusion Sets Behind an Attack

Knowing the identified Intrusion Sets and their most exploited patterns (by MITRE ATT&CK and ATLAS) allows cybersecurity experts to pinpoint the potential sources of attacks. With the unified matrix, you can select encountered attack patterns and utilize a softmax function to generate the probabilities of being under attack by the known Intrusion Sets. This approach enhances the ability to assess and prioritize threats, providing a more accurate and dynamic evaluation of the security landscape, and guiding the expert to investigate other patterns typically exploited by the identified threat groups/agents.

III. VULNERABILITY-ATTACK PATTERNS RELATIONSHIPS

To conduct a quantitative risk analysis related to an identified vulnerability, CVE, or CWE, it is essential to understand the relationships between the vulnerability and associated attack patterns. This involves mapping the vulnerability to specific attack techniques, which helps evaluate the potential impact and likelihood of exploitation. By identifying these relationships, cybersecurity analysts can prioritize mitigation efforts and improve their overall security posture.

The approach used in this work is a complex conditional one (figure 2), first of all, there is a check for what type of vulnerability is searched for, in case of a CVE the approach check if it is in **MAPPINGS EXPLORER** framework [15], otherwise is checked for CWEs related to that CVE. When there are no CWEs associated with a specific vulnerability, provision has been made for employ a machine learning (ML) model, more precisely an LLM (Large Language Model), to establish the necessary mappings. If at least one CWE is identified, the path of CWE mappings for every related

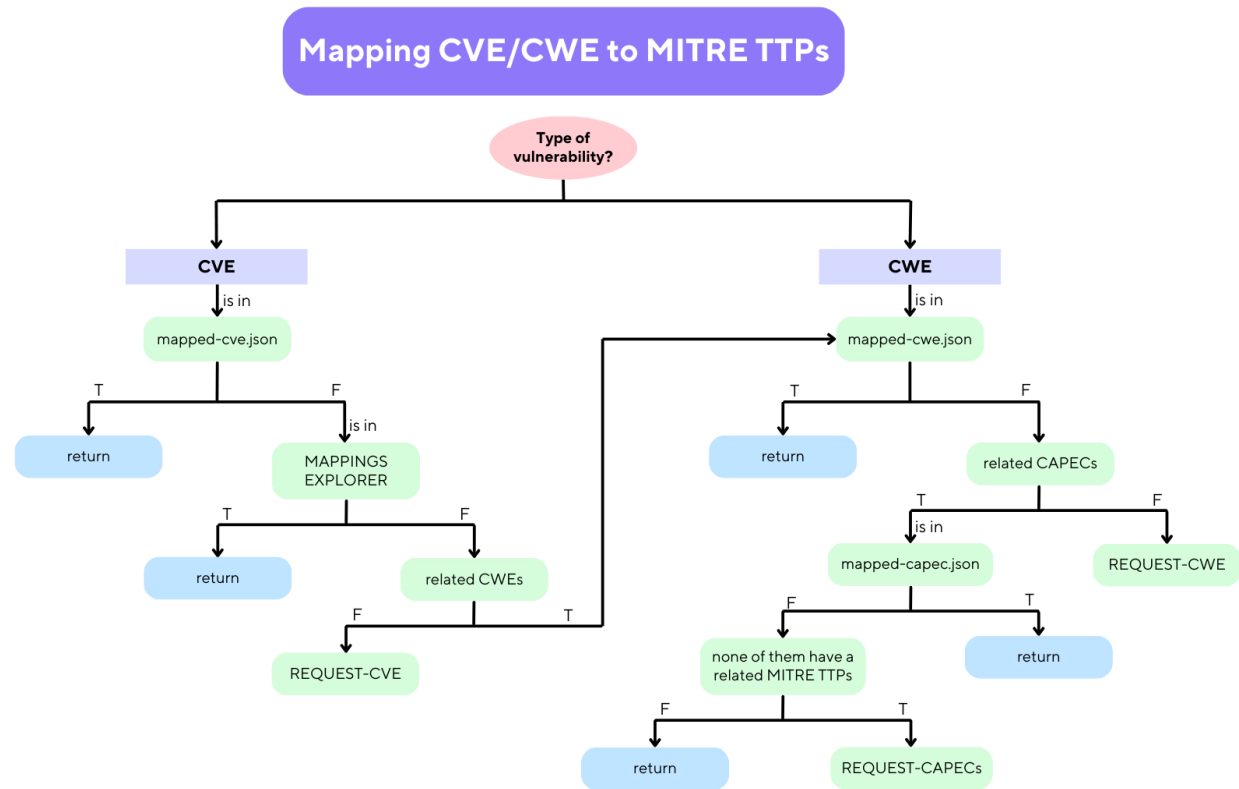


Fig. 2. Conditional approach to obtain Vulnerability-TTPs relationship.

CWEs is performed to reflect the relationships of the identified CVE(s) on the searched CVE.

While the searched vulnerability is a **CWE** the approach taken involves a method based mainly on the relationships between the CTI information. Bearing in mind that one CVE is related to zero or more CWE(s), one CWE is related to zero or more CAPEC(s)¹ (Common Attack Pattern Enumerations and Classifications), and one CAPEC is related to zero or more techniques of MITRE ATT&CK, it is possible to obtain the final relationships through the CAPEC(s). So if there is not even one CAPEC allied with a CWE an ML model is used to establish the necessary mappings, otherwise, the approach taken checks for allied attack patterns for every CAPEC and if not even one is found, it performs a query to ML model to obtain the relationship between every CAPEC and attack patterns.

This approach ensures that all possible connections between vulnerabilities and attack patterns are comprehensively evaluated, enabling more accurate and informed risk assessments. It is noted that the use of an LLM is considered in this study as a compensatory procedure, and is only used in cases where there is no linking already, in order always to have at least one pattern on which to carry out a quantitative risk analysis related to a vulnerability found.

¹<https://capec.mitre.org/>

IV. RISK SCORE ALGORITHMS

Once the vulnerability attack pattern chain has been evaluated by the previous approach, the results gathered can be used to calculate the overall organization risk assessment score. To achieve this, the proposed solution uses the Common Vulnerability Scoring System (CVSS) [16]. This tailored system allows the evaluation of any given CVE, based on pre-defined metrics, summarised in a Vector String.

A. Basic Score Approach

The most basic score calculation approach available through what is known as the "Base Score", a value included inside the CVSS metrics, is a simple average of all the single base scores, divided by the number of considered items (CVEs).

Let CVE_{list} be the list of all detected CVEs; let CVE_{bs} be the single CVE base score value; and let $len()$ be a function which counts the length (number of items) of a list. Then the Basic Score approach can be defined as:

$$score = \frac{\sum_{i=0}^n (CVE_{bsi})}{n}$$

in which:

$$n = len(CVE_{list})$$

While this approach allows for a fast, easy to comprehend, evaluation of the level of risk exposure, its simplicity also functions as its core weakness. This, in fact, does not take

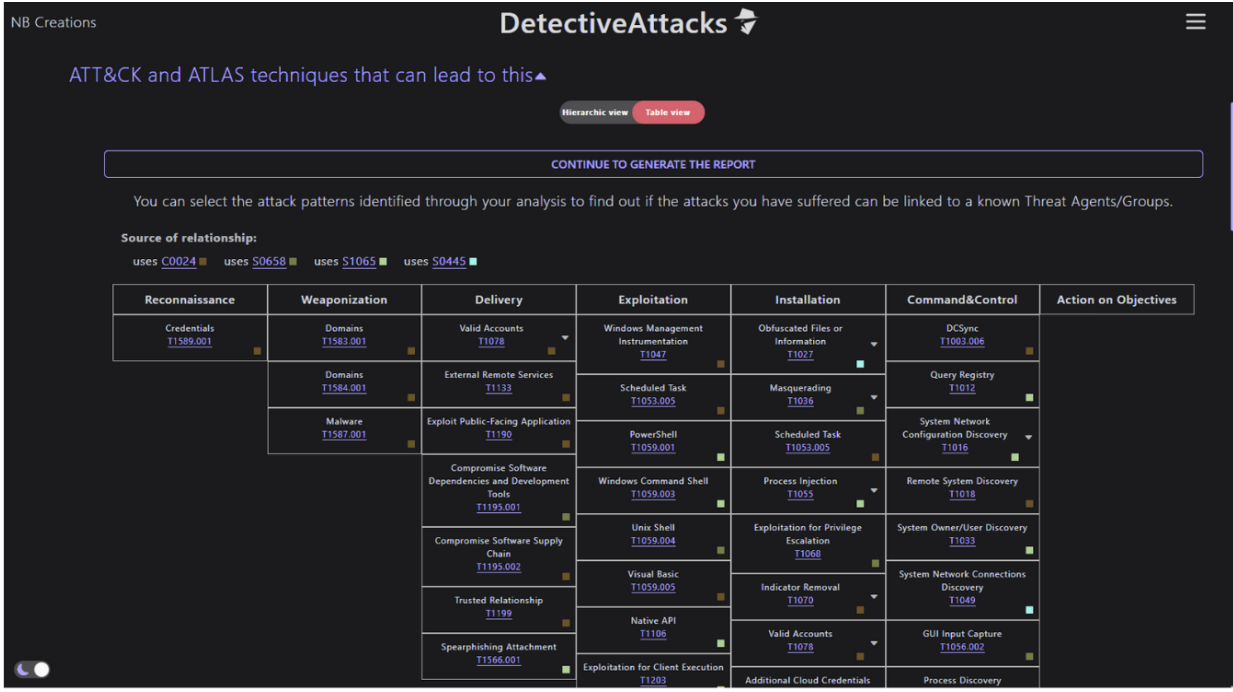


Fig. 3. Attack patterns might have preceded the pattern of Account Discovery (identified as T1087 in the MITRE ATT&CK framework).

into consideration any measure of the importance of each considered vulnerability and therefore does not evaluate them based on their relevance or impact on the organization's safety. A simple solution to this can be the definition of a weight parameter, such as the ones contemplated in the following algorithms.

B. Severity-based Score

The Severity is a mapping of each CVE base score into an ordinal scale as defined by the FIRST Org. in their *Qualitative Severity Rating Scale*. This approach enables the gathering of data into groups of classes of different vulnerabilities. This renders practical evaluation based on their belonging class value, which can be defined by the user.

Let CVE_{list} be the list of all detected CVEs; let CVE_{bs} be the single CVE base score; let $CVE_{severity}$ be the single CVE severity string; let $DICT_{severity}$ be the dictionary containing base score to severity mappings; and let $len()$ be a function which counts the length (number of items) of a list. Then the Severity-based score can be defined as:

$$score = \frac{\sum_{i=0}^n (CVE_{bsi} \cdot DICT_{severity}[CVE_{severity_i}])}{n}$$

in which:

$$n = len(CVE_{list})$$

Although this method gives the possibility to group a variety of CVEs into evaluation classes, this might imply an unremarkable result subsequent to conflicting scores being assigned to the same group. Consider, for example, the *Medium* severity class which ranges from score 4.0 to score 6.9, and two CVEs members of such class.

Consider now, one of those being valued at the lowest possible score, and the other at its highest. In this approach, both will be given the same measurement as part of the same class group, while a more detailed approach would appraise one as more *severe* than the other.

C. CWE-based Score

Another method to evaluate risk exposure is through the usage of weaknesses. This considers all the vulnerabilities and examines them to verify the presence of any CWE. For each of these, a type is made available which can be either *Primary* or *Secondary*. The proposed approach uses both the number of weaknesses and their type (mapped to an arbitrary numeric value) to evaluate a final score as follows.

Let CVE_{list} be the list of all detected CVEs; let CVE_{bs} be the single CVE base score; let CWE_{count} be number of weaknesses for the current CVE; let CWE_{type} be the type of weakness for the current CVE; let $DICT_{type}$ be the dictionary containing CWE type to arbitrary value mappings; and let $len()$ be a function which counts the length (number of items) of a list. Then the score can be defined as:

Count method:

$$a = \frac{\sum_{i=0}^n (CVE_{bsi} \cdot CWE_{count_i})}{n}$$

Type method:

$$b = \frac{\sum_{i=0}^n \left(CVE_{bsi} \cdot \left(\frac{\sum_{j=0}^{CWE_{count}} (DICT_{type}[CWE_{type_j}])}{CWE_{count}} \right) \right)}{n}$$

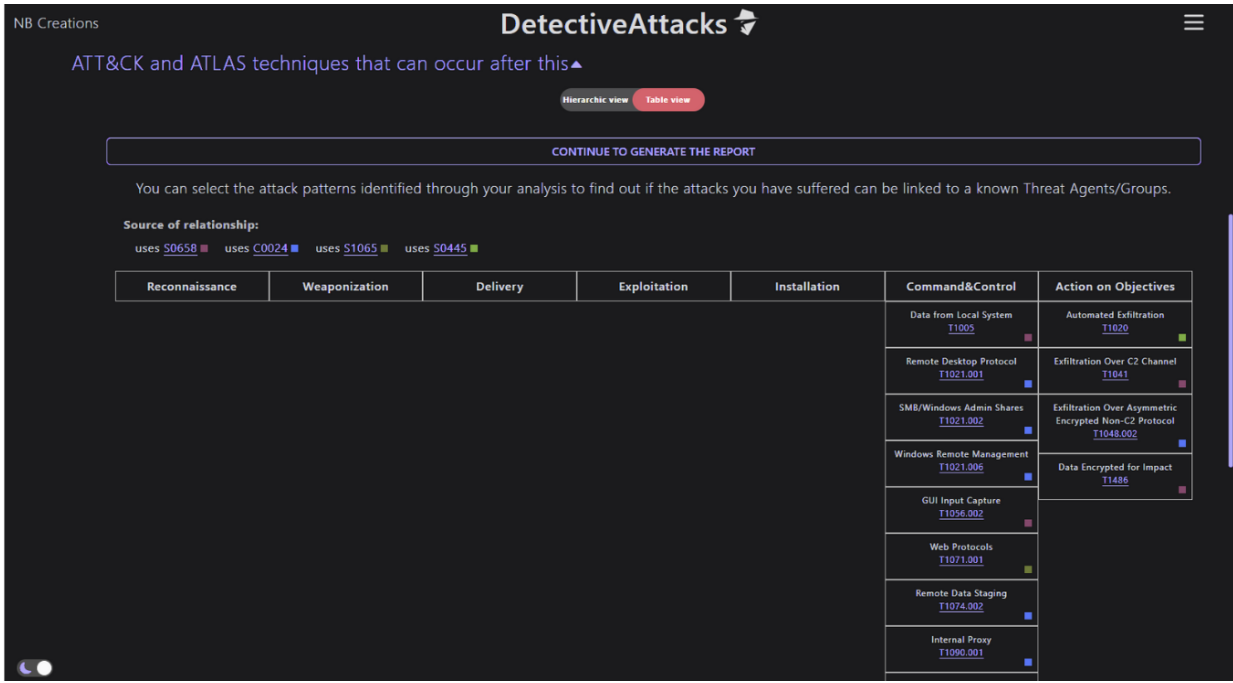


Fig. 4. Attack patterns could potentially follow the identified pattern of Account Discovery (identified as T1087 in the MITRE ATT&CK framework).

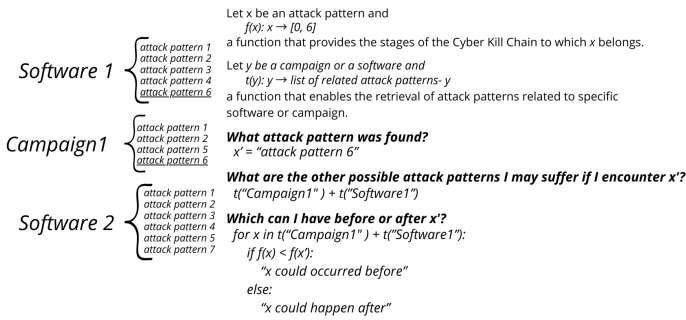


Fig. 5. How the relationships are used for patterns prevention.

Both combined:

$$score = \frac{a + b}{2}$$

in which:

$$n = len(CVE_{list})$$

This approach considers the count and type of weaknesses related to a given vulnerability and therefore escalates that to a higher grade of severity/impact inside the calculation based on the occurrences. However, since every CVE is analyzed individually, this might lead to data redundancy and thereafter a not fully significant final score.

D. Impact-based Score

The impact is intended as the consequences caused by successful exploitations on CIA Triad [17], [18] entities. In short, these are:

- Confidentiality: refers to the need to protect sensitive information from unauthorized access and/or disclosure.
- Integrity: refers to the act of protecting information from unauthorized alterations.
- Availability: refers to the commitment to guarantee that authorized individuals can easily access information when needed.

The CVSS data offers, as in the previous case, a numeric representation of the potential impact on the characteristics listed above. This value can then be used as the new weight measurement, obtaining a new approach.

Let CVE_{list} be the list of all detected CVEs; let CVE_{bs} be the single CVE base score; let CVE_{is} be the single CVE impact score; and let $len()$ be a function which counts the length (number of items) of a list. Then the Impact-based score can be defined as:

$$score = \frac{\sum_{i=0}^n (CVE_{bsi} \cdot CVE_{isi})}{n}$$

in which:

$$n = len(CVE_{list})$$

While this approach allows for the comprehension of the resulting impact on a given system or organization, it is necessary to state that: being entirely based on the presence of a set list of vulnerabilities, and their corresponding impact evaluation, this calculation **does not** consider any means of active protection that might affect the impact.

V. CONCLUSIONS

In conclusion, this paper presents a suite of methodologies designed to enhance the capabilities of cybersecurity experts

and analysts in effectively prioritizing detection and mitigation efforts against exploited vulnerabilities and attack patterns. By integrating the ATT&CK and ATLAS matrices into a unified framework, a more holistic approach to threat analysis is demonstrated. This integration not only simplifies the process of identifying preventive measures for known attack patterns but also strengthens proactive defense strategies.

The analysis of potential intrusion sets linked to detected attack patterns provides a clearer understanding of the threat landscape, enabling more targeted and effective responses. Furthermore, the proposed quantitative risk analysis methodology, which connects vulnerabilities to specific attack patterns, offers a refined risk assessment tool that improves precision in evaluating organizational risk. The introduction of tailored risk-scoring algorithms further aids in quantifying and prioritizing risks, thus supporting better-informed decision-making processes. This, combined with a flexible approach, which enables analysts to gather information about mitigation techniques and therefore allows them for a well-thought intervention, is crucial in the understanding of work effort and potential returns to further reduce an organization's risk exposure.

ACKNOWLEDGMENT

This work was partially supported by the following project: SERICS - "Security and Rights In the CyberSpace - SERICS" (PE00000014) under the MUR National Recovery and Resilience Plan funded by the European Union - NextGenerationEU; TITANUX - "CreaTing hIgh qualiTy ANd secure systems that emphasize UX", Regolamento regionale della Puglia per gli aiuti in esenzione n. 17 del 30/09/2014 (BURP n. 139 suppl. del 06/10/2014) e s.m.i. TITOLO II CAPO 2 DEL REGOLAMENTO GENERALE "Aiuti ai programmi integrati promossi da PICCOLE IMPRESE ai sensi dell'articolo 27 del Regolamento"

REFERENCES

- [1] A. Albakri, E. Boiten, and R. Smith, "Risk assessment of sharing cyber threat intelligence," in *Computer Security*, I. Boureau, C. C. Drăgan, M. Manulis, T. Giannetos, C. Dadoyan, P. Gouvas, R. A. Hallman, S. Li, V. Chang, F. Pallas, J. Pohle, and A. Sasse, Eds. Cham: Springer International Publishing, 2020, pp. 92–113.
- [2] Y. Merah and T. Kenaza, "Ontology-based cyber risk monitoring using cyber threat intelligence," in *Proceedings of the 16th International Conference on Availability, Reliability and Security*, ser. ARES '21. New York, NY, USA: Association for Computing Machinery, 2021. [Online]. Available: <https://doi.org/10.1145/3465481.3470024>
- [3] R. Riesco and V. A. Villagrà, "Leveraging cyber threat intelligence for a dynamic risk framework," *International Journal of Information Security*, vol. 18, no. 6, pp. 715–739, 2019. [Online]. Available: <https://doi.org/10.1007/s10207-019-00433-2>
- [4] B. L. Prasanna and M. SaidiReddy, "(csm2-ra-r2-ti): Cyber security maturity model for risk assessment using risk register for threat intelligence," *Journal of Physics: Conference Series*, vol. 2040, no. 1, p. 012005, oct 2021. [Online]. Available: <https://dx.doi.org/10.1088/1742-6596/2040/1/012005>
- [5] B. E. Strom, A. Applebaum, D. P. Miller, K. C. Nickels, A. G. Pennington, and C. B. Thomas, "Mitre att&ck: Design and philosophy," in *Technical report*. The MITRE Corporation, 2018.
- [6] MITRE, "MITRE ATT&CK®: Adversarial Tactics, Techniques, and Common Knowledge," 2024, accessed: 2024-09-30. [Online]. Available: <https://attack.mitre.org>
- [7] MITRE, "Mitre atlas (adversarial threat landscape for artificial-intelligence systems)," 2021. [Online]. Available: <https://atlas.mitre.org/>
- [8] M. Teresa Baldassarre, V. Santa Barletta, D. Caivano, and A. Piccinno, "Integrating security and privacy in hcd-scrum," in *Proceedings of the 14th Biannual Conference of the Italian SIGCHI Chapter*, ser. CHIItaly '21. New York, NY, USA: Association for Computing Machinery, 2021. [Online]. Available: <https://doi.org/10.1145/3464385.3464746>
- [9] Eric M. Hutchins, Michael J. Cloppert, and Rohan M. Amin, "Intelligence-driven computer network defense informed by analysis of adversary campaigns and intrusion kill chains," pp. 1–14, 2010.
- [10] B. AL-SADA, A. Sadighian, and G. Oligeri, "Mitre attack: State of the art and way forward," *ACM Comput. Surv.*, Aug. 2024, just Accepted. [Online]. Available: <https://doi.org/10.1145/3687300>
- [11] S. Bird, D. Day, J. Garofolo, J. Henderson, C. Laprun, and M. Liberman, "Atlas: A flexible and extensible architecture for linguistic annotation," 2000.
- [12] V. S. Barletta, D. Caivano, M. Calvano, A. Curci, and A. Piccinno, "Craste: Human factors and perception in cybersecurity education," vol. 3713, 2024, Conference paper, p. 75 – 81.
- [13] M. T. Baldassarre, V. S. Barletta, D. Caivano, D. Raguseo, and M. Scalera, "Teaching cyber security: The hack-space integrated model," vol. 2315, 2019, Conference paper.
- [14] MITRE, "MITRE ATT&CK GitHub Repository," 2024, accessed: 2024-09-30. [Online]. Available: <https://github.com/mitre-attack>
- [15] T. C. for Threat-Informed Defense, "Mappings explorer." [Online]. Available: <https://center-for-threat-informed-defense.github.io/mappings-explorer/>
- [16] FIRST, "Common Vulnerability Scoring System version 3.1," 2019, accessed: 2024-09-30. [Online]. Available: <https://www.first.org/cvss/calculator/3.1>
- [17] O. M. C. Osazuwa, "Confidentiality, integrity, and availability in network systems: A review of related literature," *International Journal of Innovative Science and Research Technology*, vol. 8, 2023.
- [18] S. Samonas and D. Coss, "The cia strikes back: Redefining confidentiality, integrity and availability in security," *Journal of Information System Security*, vol. 10, no. 3, 2014.